

HADESS — Penetration Tester Roadmap 2026

Source: hadeess.io/pen-test-roadmap | Compiled for Ali Khan

The Honest Prerequisites

Penetration testing has a higher technical bar than most other entry points into cybersecurity.

Strong Networking: Subnetting, routing, TCP flags, ARP, DHCP, ports, firewall filtering — used every single day.

Linux Comfort: Navigate file system, manage processes, edit files in terminal, pipe commands, troubleshoot without GUI.

Scripting Ability: Python and Bash at minimum. Read, understand, and modify code. Write custom scripts and automate tasks.

Methodology Patience: Pen testing follows OWASP, PTES, OSSTMM. Methodology keeps you thorough and ensures nothing is missed.

Timeline from zero: 12-18 months. With IT background: 8-12 months.

4-Phase Learning Roadmap

Phase	Timeline	Focus	Key Skills
Phase 1	Months 1-3	Networking & Systems	TCP/IP, Linux, Windows, Python, Bash
Phase 2	Months 4-6	Web Application Security	OWASP Top 10, Burp Suite, SQLi, XSS, IDOR
Phase 3	Months 7-9	Network & Infrastructure	Nmap, Metasploit, Privilege Escalation
Phase 4	Months 10-12	Active Directory & Post-Exploitation	BloodHound, Kerberoasting, Lateral Movement

Phase 1: Networking & Systems (Months 1-3)

- Month 1 — Study TCP/IP, routing, VLANs, subnetting. Use Wireshark to observe real protocol behavior.
- Month 2 — Deep Linux: set up Apache, SSH, FTP, MySQL from CLI. File permissions, cron jobs, user management. Windows: Active Directory basics, Group Policy, PowerShell.
- Month 3 — Write Python scripts: port scanners, web scrapers, log analyzers. Bash for automation — looping IP ranges, grepping output, piping tools.

Phase 2: Web Application Security (Months 4-6)

- Month 4 — HTTP methods, cookies, sessions, auth flows, APIs. OWASP Top 10 as a framework not a checklist. Practice on DVWA, WebGoat, Juice Shop manually before tools.
- Month 5 — Learn Burp Suite thoroughly: proxy, repeater, intruder, decoder. Manual testing: IDOR by changing parameters, JWT token manipulation, SSRF with internal URLs.
- Month 6 — Run complete web app test following OWASP Testing Guide. Write professional report with executive summary, detailed findings, severity, evidence, impact, remediation.

Phase 3: Network & Infrastructure Pen Testing (Months 7-9)

- Month 7 — OSINT: theHarvester, Recon-ng, Shodan. Nmap: service version detection, NSE scripts, scan optimization, output parsing.
- Month 8 — Metasploit modules, payloads, handlers, post-exploitation. Exploit vulnerabilities manually first, then use frameworks. Practice HTB Easy and Medium machines.
- Month 9 — Linux privesc: SUID binaries, cron job abuse, sudo misconfigs. Windows privesc: service misconfigs, DLL hijacking, token impersonation. Use GTFOBins and PayloadsAllTheThings.

Phase 4: Active Directory & Post-Exploitation (Months 10-12)

- Month 10 — Build AD lab with domain controller + workstations. BloodHound, PowerView, ADRecon. Kerberoasting, AS-REP roasting, Pass-the-Hash, DCSync.
- Month 11 — Pivoting through networks, port forwards, lateral movement. Credential harvesting: Mimikatz, SAM extraction, LSASS dumping. Demonstrate impact without harming client environment.
- Month 12 — Full simulated engagement from recon to report. Use ProLabs on HTB. Write complete professional report. This becomes your portfolio piece for interviews.

Certification Path

Priority	Certification	Why	Timeline
1st	eJPT	Entry-level validation, cheapest	Month 8-9
2nd	OSCP	Industry gold standard, opens doors	Month 12-15
3rd	OSWE / CRT0	Specialization proof	After 2 years experience

Getting Hired — What Firms Actually Look For

- Ability to work independently and manage time across multiple engagements
- Report writing quality — they will ask for a sample report at interview
- Methodology discipline, not just hacking ability
- Client communication — can you explain a vulnerability to a non-technical executive?
- Understanding of risk — knowing WHY a finding matters is as important as finding it
- Cultural fit for consulting — travel, deadlines, varied clients

Entry Points Into the Field

MSSP / Consultancy Junior Pentester: Most common path. Work under seniors, handle easier engagements, learn on the job.

SOC Analyst to Pentester: Work SOC 1-2 years, build skills on the side, transition internally or externally.

IT/Sysadmin to Pentester: Operational knowledge is valuable — many good pentesters started here.

Bug Bounty Portfolio: Strong HackerOne/Bugcrowd profile with verified findings demonstrates real-world ability.

Key Quotes From The Roadmap

"Penetration testing has a higher technical bar than most other entry points into cybersecurity. Being honest about this upfront saves people from frustration later."

"A pen tester who finds a critical vulnerability but writes a report no one can understand has failed the engagement."

"Bug bounties teach you to find real vulnerabilities in production applications, but alone are not enough preparation for pen testing."

"The OSCP is the certification that opens doors. Plan to spend 2-3 months of focused preparation."

Source: hadess.io/pen-test-roadmap | Compiled by Claude for Ali Khan | August 2026